La géopolitique de la cybersécurité : dépendances numériques et résilience organisationnelle

Analyse conceptuelle et implications pour la gouvernance des risques cyber

Auteur : Innocent Twagirumukiza | **Date :** 13 octobre 2026 | **Type :** Analyse conceptuelle

Domaine : Cybersécurité, GRC, résilience organisationnelle

RÉSUMÉ

La cybersécurité des organisations ne peut plus être analysée uniquement à partir du périmètre de leur système d'information. Les dépendances aux fournisseurs de services numériques, aux infrastructures critiques, aux chaînes d'approvisionnement logicielles et aux technologies d'intelligence artificielle contribuent à élargir leur exposition aux risques. Dans un contexte de tensions géopolitiques, ces dépendances peuvent constituer des vecteurs de propagation des incidents et affecter la continuité des activités.

Cet article examine les implications de cette évolution pour la gouvernance, la gestion des risques et la conformité (GRC). Il défend l'idée que l'analyse du risque cyber doit intégrer les dépendances organisationnelles et technologiques, les conséquences d'une indisponibilité prolongée et les capacités de fonctionnement en mode dégradé. Il propose ainsi un déplacement du regard : de la protection du système d'information vers la résilience de l'organisation et de son écosystème.

Cette contribution s'appuie sur une analyse documentaire des rapports institutionnels (ENISA Threat Landscape 2025 et 2026, Boîte à outils UE pour la sécurité de la chaîne d'approvisionnement des TIC, conclusions du Conseil de l'UE sur les menaces hybrides) et sur des études de cas documentées (NotPetya/Maersk, SolarWinds, réseau électrique ukrainien, Change Healthcare, terres rares, intelligence artificielle).

Mots-clés : cybersécurité ; gestion des risques ; dépendances numériques ; résilience organisationnelle ; géopolitique ; chaîne d'approvisionnement ; gouvernance ; GRC ; intelligence artificielle.

ABSTRACT (ENGLISH)

Organisational cybersecurity can no longer be analysed solely from the perimeter of the information system. Dependencies on digital service providers, critical infrastructure, software supply chains and artificial intelligence technologies expand exposure to risk. In a context of geopolitical tensions, these dependencies can act as vectors for the propagation of incidents and affect business continuity.

This article examines the implications for governance, risk management and compliance (GRC). It argues that cyber risk analysis must integrate organisational and technological dependencies, the consequences of prolonged unavailability and the capacity to operate in degraded mode. It proposes a shift from protecting the information system towards the resilience of the organisation and its ecosystem.

The contribution is grounded in institutional reports (ENISA Threat Landscape 2025 and 2026, EU ICT Supply Chain Security Toolbox, Council of the EU conclusions on hybrid threats) and documented case studies (NotPetya/Maersk, SolarWinds, Ukrainian power grid, Change Healthcare, rare earths, artificial intelligence).

Keywords: cybersecurity; risk management; digital dependencies; organisational resilience; geopolitics; supply chain; governance; GRC; artificial intelligence.

1. Introduction

Les conflits contemporains ne se jouent plus seulement sur les champs de bataille. Ils se prolongent dans les réseaux, les chaînes d'approvisionnement, les infrastructures critiques et les systèmes d'information. Pour les entreprises et les organisations publiques, cela change profondément la manière de penser le risque cyber.

Pendant longtemps, la guerre et la cybersécurité semblaient appartenir à deux univers différents. Cette séparation est devenue beaucoup plus difficile à maintenir. Les conflits contemporains s'accompagnent désormais d'opérations cyber, d'espionnage numérique, d'attaques contre des infrastructures critiques, de campagnes de désinformation et d'actions visant les chaînes logistiques ou technologiques.

Le Conseil de l'Union européenne constate lui-même que les tensions géopolitiques, les conflits et les rivalités stratégiques se reflètent dans l'impact, le volume et la sophistication des activités cyber malveillantes, lesquelles peuvent s'inscrire dans des campagnes hybrides ou des opérations militaires (Conseil de l'Union européenne, 2026).

> La cybersécurité n'est donc plus seulement une question technique. Elle devient progressivement une question de **résilience stratégique**.

Précision méthodologique. Dans la suite de l'article, les faits tirés des rapports institutionnels (ENISA, Commission européenne / Groupe de coopération SRI, Conseil de l'UE) et des sources primaires sur les incidents sont présentés comme **constats documentés**. Les liens établis entre ces constats et la géopolitique des dépendances relèvent d'une **interprétation**. Les recommandations de gouvernance (section 10) constituent des **propositions de l'auteur**.

2. L'entreprise n'a pas besoin d'être une cible pour être exposée

Une organisation peut ne présenter aucun intérêt politique ou militaire particulier et pourtant être touchée par un conflit, parce qu'elle appartient à un écosystème : fournisseur cloud, opérateur télécom, prestataire informatique, logiciels développés à l'étranger, énergie, banque, sous-traitance, infrastructures partagées.

Une attaque contre l'un de ces acteurs peut produire des conséquences en cascade. C'est l'une des tendances relevées par l'ENISA : les attaquants exploitent davantage les dépendances numériques et les points critiques des chaînes d'approvisionnement (ENISA, 2025 ; ENISA, 2026).

Le raisonnement « Suis-je une cible ? » devient insuffisant. La question pertinente devient : **« De quoi mon activité dépend-elle et qui pourrait utiliser cette dépendance contre moi ? »**

3. La supply chain devient un champ de bataille

Un attaquant n'a pas nécessairement besoin d'attaquer directement une grande organisation. Il peut cibler un fournisseur moins protégé. La compromission d'un maillon ouvre ensuite une voie vers plusieurs organisations.

Les rapports ENISA Threat Landscape 2025 et 2026 documentent l'intensification du ciblage des dépendances cyber (ENISA, 2025 ; ENISA, 2026). Dans le même sens, la **Boîte à outils de l'UE pour la sécurité de la chaîne d'approvisionnement des TIC**, adoptée le 13 février 2026 par le groupe de coopération SRI, fournit une approche commune pour identifier, évaluer et atténuer les risques, y compris les dépendances à l'égard de fournisseurs à haut risque (Commission européenne / Groupe de coopération SRI, 2026).

La conséquence pour la GRC : le risque fournisseur ne peut plus se limiter à un questionnaire annuel de conformité. Il faut cartographier les dépendances réelles et anticiper les effets de cascade.

4. Les infrastructures civiles deviennent stratégiques

Transport, énergie, télécommunications, finance, santé, administration… Ces infrastructures sont indispensables au fonctionnement d'un pays et deviennent des cibles naturelles en confrontation hybride. Une cyberattaque contre un système industriel peut avoir des conséquences physiques. Les analyses de l'ENISA confirment que l'administration publique, le transport et les infrastructures numériques figurent parmi les plus ciblés (ENISA, 2025).

4 bis. Les dépendances critiques comme vecteurs de propagation du risque géopolitique

4 bis.1. Au-delà du système d'information : une approche élargie de la dépendance

L'analyse du risque cyber demeure souvent structurée autour des actifs directement administrés : postes, serveurs, applications, réseaux, identités, données. Cette approche est nécessaire, mais insuffisante.

Une organisation dépend aussi de ressources qu'elle ne contrôle que partiellement : logiciels tiers, cloud, télécoms, prestataires de paiement, systèmes industriels, composants électroniques, réseaux énergétiques, chaînes d'approvisionnement internationales.

On distingue le **périmètre technique de sécurité** (systèmes sur lesquels l'organisation exerce directement des mesures de protection) et le **périmètre de dépendance** (ressources dont l'indisponibilité ou la compromission peut empêcher de remplir les missions).

Une dépendance devient un facteur de risque stratégique lorsque plusieurs conditions sont réunies : forte concentration de l'offre, difficulté de substitution, délai de remplacement important, faible maîtrise de la technologie, exposition à des décisions politiques et tensions internationales.

Les études de cas suivantes n'ont pas toutes le même statut : certaines relèvent d'opérations cyber documentées, d'autres de décisions économiques. Leur rapprochement est analytique et ne signifie pas une cause unique.

4 bis.2. NotPetya et Maersk : lorsqu'une attaque devient un risque économique transnational

L'incident NotPetya de juin 2017 constitue un exemple majeur de propagation du risque cyber. Le logiciel malveillant s'est propagé internationalement après avoir été introduit dans une chaîne de distribution logicielle utilisée en Ukraine. A. P. Moller-Maersk a confirmé que ses systèmes avaient été touchés.

Dans son rapport annuel 2017, Maersk estimait les pertes entre 250 et 300 millions de dollars (pertes de revenus, restauration informatique, dépenses opérationnelles exceptionnelles) (A. P. Moller–Maersk, 2018).

Mécanisme de propagation en cascade : compromission logicielle → systèmes internes → opérations physiques, clients et partenaires. L'interconnexion internationale transforme un incident informatique en problème de continuité économique.

NotPetya s'inscrit dans le contexte du conflit russo-ukrainien et a fait l'objet d'attributions officielles à des acteurs russes. L'impact mondial montre qu'une action régionale peut produire des conséquences économiques bien au-delà du théâtre initial.

Enseignement : la résilience d'une organisation dépend aussi de sa capacité à contenir les effets d'une attaque qui ne la visait pas nécessairement en priorité.

4 bis.3. SolarWinds : la confiance accordée aux fournisseurs comme enjeu stratégique

La compromission de la plateforme Orion de SolarWinds, révélée en décembre 2020, illustre la dépendance fondée sur la confiance dans les outils logiciels et leurs mécanismes de mise à jour.

Des versions légitimes avaient été altérées pour y intégrer le code malveillant SUNBURST. Les mises à jour distribuées aux clients ont constitué un vecteur d'intrusion. Le CERT-FR a documenté l'incident et recommandé de vérifier les versions et de rechercher les signes de compromission (CERT-FR, 2020).

Un logiciel de supervision dispose souvent d'une visibilité étendue. La conformité d'un fournisseur, la légitimité d'une mise à jour et la réputation d'un éditeur ne suffisent pas à garantir l'intégrité d'une chaîne logicielle. La relation de confiance constitue elle-même une composante du risque.

Enseignement : la sécurité d'une organisation ne peut pas reposer exclusivement sur la confiance accordée aux composants logiciels dont elle dépend.

4 bis.4. Le réseau électrique ukrainien : la dépendance numérique comme vulnérabilité des infrastructures essentielles

La cyberattaque de décembre 2015 contre des opérateurs de distribution d'électricité en Ukraine a provoqué des coupures touchant environ 225 000 clients pendant une à six heures. Les attaquants avaient compromis des systèmes de contrôle industriels et utilisé les interfaces de commande pour interrompre le service (U.S. Department of Energy / CISA).

L'indisponibilité d'un système de contrôle peut affecter directement la distribution d'une ressource indispensable. L'énergie alimente télécoms, centres de données, équipements médicaux, installations industrielles et transport.

La portée géopolitique est manifeste : les infrastructures civiles peuvent être visées dans un contexte de confrontation. La gravité dépend aussi des capacités de détection, des procédures manuelles de reprise, de la redondance et de la coordination avec les autorités.

Enseignement : protéger une infrastructure critique signifie préserver sa capacité à fournir un service, y compris lorsque ses systèmes numériques sont compromis.

4 bis.5. Change Healthcare : quand la dépendance à un intermédiaire devient un risque systémique

La cyberattaque par rançongiciel subie par Change Healthcare en février 2024 illustre les conséquences d'une forte dépendance à un intermédiaire numérique dans le secteur de la santé.

Selon le Government Accountability Office américain, l'incident a entraîné des perturbations à grande échelle. Le rapport de novembre 2024 fait état de pertes estimées à 874 millions de dollars et de répercussions sur la prise en charge des patients (U.S. GAO, 2024).

Lorsqu'un prestataire occupe une position centrale, son indisponibilité peut affecter simultanément des organisations juridiquement et opérationnellement indépendantes. Il faut toutefois distinguer l'impact systémique de l'intention stratégique : cet incident démontre les conséquences d'une dépendance centralisée ; il ne suffit pas, à lui seul, à établir une opération de déstabilisation étatique.

Enseignement : un fournisseur peut devenir un point de défaillance commun à de nombreuses organisations, même lorsque chacune dispose de ses propres dispositifs de cybersécurité.

4 bis.6. Les systèmes frigorifiques de la grande distribution : illustration des effets physiques du risque numérique

Lorsqu'un dispositif numérique participe au contrôle de la température, une défaillance informatique peut, selon l'architecture et les circonstances, compromettre la conservation des produits et imposer des mesures d'urgence.

L'analyse se concentre ici sur le **mécanisme de risque**, sans confondre scénario plausible et incident démontré. Une même technologie déployée dans plusieurs magasins peut créer une dépendance commune. La dimension géopolitique ne doit pas être présumée sans preuves d'une exploitation délibérée dans un contexte de confrontation.

Enseignement : la cybersécurité des systèmes techniques doit être évaluée à partir des conséquences possibles sur l'activité réelle, et pas uniquement à partir des données qu'ils traitent.

4 bis.7. Les terres rares : lorsque la dépendance matérielle complète la dépendance numérique

Selon l'Agence internationale de l'énergie, la Chine représentait en 2024 environ 60 % de la production minière mondiale des terres rares utilisées dans les aimants, 91 % de leur production raffinée et 94 % de la fabrication mondiale des aimants permanents frittés concernés (IEA, 2025).

Les restrictions à l'exportation annoncées par la Chine en avril 2025 ont illustré les conséquences de cette concentration : difficultés d'approvisionnement pour des constructeurs automobiles en Europe, aux États-Unis et ailleurs.

Ce cas ne constitue pas une cyberattaque. Il élargit l'analyse de la résilience : une organisation peut disposer d'une infrastructure numérique correctement sécurisée et rester vulnérable à une décision extérieure qui compromet l'accès à un composant indispensable.

Enseignement : la résilience numérique dépend également de ressources matérielles et industrielles dont la disponibilité peut être influencée par les rapports de puissance internationaux.

4 bis.8. Synthèse comparative : six mécanismes de dépendance

Les études de cas ne sont pas interchangeables. Elles mettent en évidence des mécanismes différents :

- **NotPetya / Maersk (2017)** — logiciels et chaîne logistique → propagation transnationale et interruption d'activité
- **SolarWinds (2020)** — logiciel de supervision et mises à jour → compromission d'une chaîne logicielle de confiance
- **Réseau électrique ukrainien (2015)** — systèmes de contrôle industriels → perturbation d'un service essentiel
- **Change Healthcare (2024)** — intermédiaire numérique central → indisponibilité affectant un secteur entier
- **Systèmes frigorifiques** — équipements techniques connectés → scénario de perturbation aux conséquences physiques
- **Terres rares (2025)** — matières premières et transformation → restriction d'approvisionnement

Trois enseignements transversaux : (1) une dépendance est particulièrement sensible lorsqu'elle est difficile à remplacer et conditionne une fonction essentielle ; (2) l'interconnexion amplifie les conséquences au-delà du point d'origine ; (3) les vulnérabilités peuvent résulter d'une attaque informatique, d'une concentration industrielle ou d'une décision commerciale en contexte géopolitique. Ces mécanismes ne doivent pas être assimilés les uns aux autres.

4 bis.9. L'intelligence artificielle : nouvelle frontière de la puissance géopolitique et de la cybersécurité

L'IA transforme les conditions de la sécurité numérique. Elle repose sur des ressources interdépendantes : semi-conducteurs spécialisés, infrastructures de calcul, centres de données, énergie, données d'entraînement, modèles, compétences, services cloud. La maîtrise de ces ressources est inégalement répartie.

Une organisation peut être propriétaire de ses données tout en dépendant d'un fournisseur extérieur pour un modèle d'IA, des traitements ou un service essentiel. L'IA renforce la défense (analyse de journaux, détection, assistance) tout en bénéficiant aux acteurs offensifs (hameçonnage, ingénierie sociale, automatisation). L'ENISA analyse l'intégration progressive de l'IA dans les opérations malveillantes (ENISA, 2025).

L'IA devient elle-même une surface d'attaque. Le NIST a formalisé des catégories d'attaques sur les systèmes d'apprentissage automatique : évasion, empoisonnement des données, portes dérobées, atteintes à la confidentialité (Vassilev et al., 2024).

Les restrictions à l'exportation de technologies de calcul avancé illustrent comment les composants nécessaires à l'IA sont devenus des instruments de politique de sécurité nationale (U.S. Department of Commerce / BIS, 2025).

> **Enseignement :** la résilience organisationnelle à l'ère de l'IA ne repose plus uniquement sur la protection des SI. Elle dépend aussi de la capacité à maîtriser les dépendances numériques, matérielles et algorithmiques, et à préserver les fonctions essentielles lorsque l'accès à une technologie critique est compromis.

5. Du ransomware à la confrontation géopolitique

Un ransomware peut poursuivre un objectif financier ; une DDoS, des hacktivistes ; une opération d'espionnage, un acteur étatique. Les catégories se chevauchent. Les objectifs peuvent être : collecte de renseignement, préparation d'une opération, déstabilisation, perturbation, test de capacité, pression, influence, effet économique.

Le cyber devient une composante de la guerre hybride : cyberattaque + espionnage + désinformation + pression économique + sabotage + influence (Conseil de l'Union européenne, 2026).

6. L'IA accélère encore le phénomène

L'ENISA observe l'utilisation croissante de l'IA pour le phishing et l'ingénierie sociale, ainsi que des risques liés à la chaîne d'approvisionnement de l'IA (ENISA, 2025 ; ENISA, 2026). Question centrale : **De quoi dépend notre IA ?** Modèle, cloud, données, API, infrastructure, éditeur, GPU, chaîne logicielle.

7. Passer de la sécurité à la résilience

La question « Comment empêcher l'attaque ? » reste essentielle mais ne suffit plus. Il faut aussi demander : que se passe-t-il si nous sommes attaqués ? Combien de temps pouvons-nous fonctionner ? Que se passe-t-il si un fournisseur critique est indisponible ? La résilience devient une capacité organisationnelle.

8. Le périmètre de risque n'est plus le SI

Le risque se situe désormais aussi dans les identités, fournisseurs, clouds, partenaires, logiciels, IA, infrastructures, télécoms, dépendances énergétiques, chaînes logistiques et de valeur.

> Le système d'information n'est plus le périmètre du risque. Il n'en est qu'une composante. Et les guerres contemporaines rendent cette réalité beaucoup plus visible.

8 bis. De la cartographie des systèmes à la cartographie des dépendances critiques

Le RSSI ne peut plus se limiter à évaluer le niveau de protection des actifs sous responsabilité directe. Il doit contribuer à identifier les dépendances dont l'indisponibilité pourrait compromettre les fonctions essentielles — sans se substituer aux achats, opérations, continuité ou intelligence économique, mais dans une gouvernance transversale.

Cinq questions opérationnelles :

- **Dépendance** : quelles ressources externes sont indispensables ?
- **Concentration** : plusieurs fonctions critiques reposent-elles sur un même fournisseur, technologie ou zone géographique ?
- **Substitution** : combien de temps pour remplacer un fournisseur, logiciel, composant ou équipement indisponible ?
- **Propagation** : quelles activités, filiales, infrastructures ou partenaires seraient affectés ?
- **Résilience** : quelles fonctions peuvent être maintenues en mode dégradé, pendant combien de temps, avec quels moyens ?

La dimension géopolitique s'appuie sur des facteurs observables : restrictions commerciales, tensions diplomatiques, concentration industrielle, infrastructures à l'étranger, contraintes juridiques, sanctions, accès à la maintenance — non sur la seule nationalité d'un fournisseur.

Le RSSI ne doit pas seulement chercher à protéger ce que l'organisation possède, mais aussi à comprendre ce qui lui permet de fonctionner et ce qui pourrait l'empêcher de poursuivre ses activités.

9. La nouvelle question du RSSI et de la gouvernance

Au-delà de « Sommes-nous suffisamment protégés ? » : de quoi notre activité dépend-elle réellement ? Quelles dépendances pourraient devenir critiques en crise géopolitique ? Que se passe-t-il si un fournisseur stratégique disparaît 48 h, une semaine ou un mois ? Sommes-nous capables de fonctionner en environnement dégradé ?

C'est là que cybersécurité, GRC, gestion des risques, continuité d'activité et intelligence géopolitique se rejoignent.

Définition de la cyber-résilience retenue : ne pas seulement empêcher la crise d'entrer dans l'organisation, mais être capable de continuer à fonctionner lorsqu'elle est déjà là.

10. Implications opérationnelles pour la GRC

Les sections précédentes s'appuient sur des **constats documentés** et une **interprétation géopolitique**. Les propositions suivantes sont des **recommandations de gouvernance formulées par l'auteur** ; elles ne constituent pas des conclusions empiriques.

- **Cartographier les dépendances réelles** plutôt que de se limiter aux questionnaires de conformité annuels.
- **Intégrer la dimension géopolitique** dans l'analyse des risques fournisseurs et des chaînes d'approvisionnement.
- **Tester le fonctionnement en mode dégradé** (indisponibilité d'un fournisseur critique 48 h, une semaine, un mois).
- **Élargir le périmètre de la continuité d'activité** aux dépendances numériques externes.
- **Considérer l'IA et sa chaîne d'approvisionnement** comme un domaine de dépendance à documenter et sécuriser.
- **Faire converger** cybersécurité, GRC, continuité et intelligence géopolitique au niveau de la direction des risques.

Note de l'auteur. *Cet article constitue une analyse conceptuelle fondée sur des sources institutionnelles publiques et des cas documentés. Il ne prétend pas constituer une étude empirique originale ni une validation par les pairs au sens strict des revues scientifiques à comité de lecture. Il vise à éclairer les décideurs et les praticiens de la GRC et de la cybersécurité sur l'évolution du périmètre de risque dans un contexte géopolitique tendu.*

Références

1. Conseil de l'Union européenne. (2026, 16 mars). *Council adopts conclusions on advancing the EU's capacity to counter hybrid threats* (Press release 192/26). https://www.consilium.europa.eu/en/press/press-releases/2026/03/16/council-adopts-conclusions-on-advancing-the-eu-s-capacity-to-counter-hybrid-threats/
2. ENISA. (2025, 1 octobre). *ENISA Threat Landscape 2025*. European Union Agency for Cybersecurity. https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025
3. ENISA. (2026, 22 septembre). *ENISA Threat Landscape 2026*. European Union Agency for Cybersecurity. https://www.enisa.europa.eu/publications/enisa-threat-landscape-2026
4. ENISA. (2026, 22 septembre). *Exploring the evolution of the cyber threat landscape: How dependencies weaken our digital resilience* [Press release]. https://www.enisa.europa.eu/news/exploring-the-evolution-of-the-cyber-threat-landscape-how-dependencies-weaken-our-digital-resilience
5. Commission européenne / Groupe de coopération SRI. (2026, 13 février). *Boîte à outils pour améliorer la sécurité de la chaîne d'approvisionnement des TIC*. https://digital-strategy.ec.europa.eu/fr/library/toolbox-improve-ict-supply-chain-security
6. A. P. Moller–Maersk. (2018). *Annual Report 2017*. https://www.maersk.com/
7. CERT-FR. (2020, mise à jour 2021). *Présence de code malveillant dans SolarWinds Orion* (Alerte CERTFR-2020-ALE-026). https://www.cert.ssi.gouv.fr/
8. U.S. Department of Energy / CISA. Documentation sur l'attaque du réseau électrique ukrainien (2015). https://www.cisa.gov/
9. U.S. Government Accountability Office. (2024). *Healthcare Cybersecurity: HHS Continues to Have Challenges as Lead Agency* (GAO-25-107755). https://www.gao.gov/
10. International Energy Agency. (2025). *With new export controls on critical minerals, supply concentration risks become reality*. https://www.iea.org/
11. Vassilev, A., Oprea, A., Fordyce, A. & Andersen, H. (2024). *Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations* (NIST AI 100-2e2023). https://doi.org/10.6028/NIST.AI.100-2e2023
12. U.S. Department of Commerce, Bureau of Industry and Security. (2025). *Framework for Artificial Intelligence Diffusion*. Federal Register, 90 FR 4544.

Comment citer cet article :
Twagirumukiza, I. (2026). La géopolitique de la cybersécurité : dépendances numériques et résilience organisationnelle. *Analyse conceptuelle*. https://twagirumukiza.github.io/Geopolitique-et-cybersecurite/au-dela-du-systeme-d-information.html
Version bilingue complète (FR/EN) disponible sur la page HTML.